

Relatório de Análise de Segurança - Manus-Bounty

Alvo: <https://www.google.com> Data da Análise: 2025-10-27 23:15:22

1. Dados de Reconhecimento

Chave	Valor
URL Final	https://www.google.com/
Status HTTP	200

1.1. Cabeçalhos de Resposta

Cabeçalho	Valor
Date	Tue, 28 Oct 2025 03:15:03 GMT
Expires	-1
Cache-Control	private, max-age=0
Content-Type	text/html; charset=UTF-8
Content-Security-Policy-Report-Only	object-src 'none';base-uri 'self';script-src 'nonce-nQz8ovdzRPdZ4p-0xaeFKA' 'strict-dynamic' 'report-sample' 'unsafe-inline' https: http:;report-uri https://csp.withgoogle.com/csp/gws/other-hp
Cross-Origin-Opener-Policy	same-origin-allow-popups; report-to="gws"
Report-To	{"group":"gws","max_age":2592000,"endpoints":[{"url":"https://csp.withgoogle.com/csp/report-to/gws/other"}]}
Accept-CH	Sec-CH-Prefers-Color-Scheme, Downlink, RTT, Sec-CH-UA-Form-Factors, Sec-CH-UA-Platform, Sec-CH-UA-Platform-Version, Sec-CH-UA-Arch, Sec-CH-UA-Model, Sec-CH-UA-Bitness, Sec-CH-UA-Full-Version-List, Sec-CH-UA-WoW
Permissions-Policy	unload=()
P3P	CP="This is not a P3P policy! See g.co/p3phelp for more info."
Content-Encoding	br
Server	gws
X-XSS-Protection	0
X-Frame-Options	SAMEORIGIN
Set-Cookie	AEC=AaJma5v1TB5ugoD6pzdk2AmU0Wrme3vHSazqD44QS4QUwFRJZNIEeDdMWQ; expires=Sun, 26-Apr-2026 03:15:03 GMT; path=domain=.google.com; Secure; HttpOnly; SameSite=lax, NID=526=thYYE09gMxjmdxLMPBNqm7uTa1d1Dd67FZKq0FtiSc0GnowSN5RXec96kHNMylcdlvU0EeF8HI0xn5HdD47hnTU5xJK5jwChDPHhEikje1a4UYdcPS0mzSRYx68iPnKQ34hFZ77G56g40-c0mbnUe0a6XcwrunkfJXl8BGU3rJ-bi45_nZF5zu-hYzTbnF0ys5o; expires=Wed 03:15:03 GMT; path=/; domain=.google.com; Secure; HttpOnly; SameSite=none
Alt-Svc	h3=":443"; ma=2592000,h3-29=":443"; ma=2592000
Transfer-Encoding	chunked

1.2. Endpoints Descobertos (Crawler)

Foram descobertos **11** endpoints através do crawling.

```
https://www.google.com
https://www.google.com/intl/en/about.html?
https://www.google.com/intl/en/policies/terms/?
http://www.google.com/history/optout?hl=en
https://www.google.com/imghp?hl=en&tab=wi
https://www.google.com/preferences?hl=en
https://www.google.com/advanced_search?hl=en&authuser=0
https://www.google.com/intl/en/about/products?tab=wh
https://www.google.com/intl/en/ads/?
https://www.google.com/services/?
https://www.google.com/intl/en/policies/privacy/?
```

2. Achados de Segurança (Scanner & Fuzzer)

Total de 5 achados brutos (antes da análise de IA).

2.1. Achado: Missing Security Header

Severidade Bruta: Medium

Descrição: O cabeçalho de segurança 'Strict-Transport-Security' está ausente.

Detalhes: Este cabeçalho é crucial para mitigar ataques como Strict-Transport-Security.

2.2. Achado: Missing Security Header

Severidade Bruta: Medium

Descrição: O cabeçalho de segurança 'X-Content-Type-Options' está ausente.

Detalhes: Este cabeçalho é crucial para mitigar ataques como X-Content-Type-Options.

2.3. Achado: Weak Security Header Configuration

Severidade Bruta: Low

Descrição: O cabeçalho 'X-Frame-Options' está presente, mas com configuração potencialmente fraca.

Detalhes: Valor esperado: começar com 'DENY'. Valor atual: 'SAMEORIGIN'.

2.4. Achado: Missing Security Header

Severidade Bruta: Medium

Descrição: O cabeçalho de segurança 'Content-Security-Policy' está ausente.

Detalhes: Este cabeçalho é crucial para mitigar ataques como Content-Security-Policy.

2.5. Achado: Missing Security Header

Severidade Bruta: Medium

Descrição: O cabeçalho de segurança 'Referrer-Policy' está ausente.

Detalhes: Este cabeçalho é crucial para mitigar ataques como Referrer-Policy.

3. Análise Inteligente de IA

A IA analisou 5 achados e forneceu *insights* e **mitigações**.

3.1. Análise de Vulnerabilidade

Falha Original: O cabeçalho de segurança 'Strict-Transport-Security' está ausente.

Severidade Reavaliada (IA): High

Resumo da Implicação (IA):

A ausência do cabeçalho Strict-Transport-Security expõe o site a ataques de downgrade de protocolo, permitindo conexões inseguras HTTP.

Sugestões de Mitigação (IA):

Configurar o cabeçalho Strict-Transport-Security (HSTS) com no mínimo `'max-age=31536000; includeSubDomains; preload'` para forçar o uso de HTTPS e proteger contra ataques de interceptação.

3.2. Análise de Vulnerabilidade

Falha Original: O cabeçalho de segurança 'X-Content-Type-Options' está ausente.

Severidade Reavaliada (IA): Medium

Resumo da Implicação (IA):

Sem o cabeçalho X-Content-Type-Options, o navegador pode interpretar erroneamente tipos MIME dos recursos, aumentando o risco de ataques de injeção.

Sugestões de Mitigação (IA):

Incluir o cabeçalho X-Content-Type-Options com o valor `'nosniff'` para garantir que o navegador respeite o tipo MIME declarado e evitar ataques baseados em MIME sniffing.

3.3. Análise de Vulnerabilidade

Falha Original: O cabeçalho 'X-Frame-Options' está presente, mas com configuração potencialmente fraca.

Severidade Reavaliada (IA): Low

Resumo da Implicação (IA):

O valor 'SAMEORIGIN' permite que a página seja incorporada em iframes do mesmo domínio, o que pode ser aceitável mas tem menor proteção contra clickjacking comparado a 'DENY'.

Sugestões de Mitigação (IA):

Avaliar a necessidade `real` de permitir 'SAMEORIGIN'. Se possível, alterar para 'DENY' para impedir completamente o carregamento da página em iframes, prevenindo ataques de clickjacking.

3.4. Análise de Vulnerabilidade

Falha Original: O cabeçalho de segurança 'Content-Security-Policy' está ausente.

Severidade Reavaliada (IA): High

Resumo da Implicação (IA):

Sem a Content-Security-Policy, a aplicação está vulnerável a ataques de Cross-Site Scripting (XSS) e injeção de conteúdo malicioso.

Sugestões de Mitigação (IA):

Implementar uma política de Content-Security-Policy restritiva, definindo fontes confiáveis para scripts, estilos e outros recursos para reduzir riscos de injeção de código.

3.5. Análise de Vulnerabilidade

Falha Original: O cabeçalho de segurança 'Referrer-Policy' está ausente.

Severidade Reavaliada (IA): Medium

Resumo da Implicação (IA):

A ausência do Referrer-Policy pode levar ao envio excessivo de informações sensíveis via cabeçalhos HTTP Referer para terceiros.

Sugestões de Mitigação (IA):

Configurar o cabeçalho Referrer-Policy com uma política adequada como 'strict-origin-when-cross-origin' para limitar o compartilhamento de informações de referência.

4. Conclusão e Uso Ético

Este relatório foi gerado pelo Manus-Bounty com o objetivo de auxiliar na **identificação defensiva** de falhas de segurança. Todos os achados devem ser **verificados manualmente** e reportados de acordo com as diretrizes do programa de Bug Bounty ou política de segurança do alvo.

Lembre-se: O uso desta ferramenta deve ser **sempre ético e autorizado**.